Q17. Email routing, SPF, DKIM and DMARC

Original question: Examine the routing and authentication information in a supplied email message. Analyze the available SPF, DKIM, and DMARC results and explain how these findings help assess email authenticity.

Aim

Examine Received and authentication headers, interpret available SPF/DKIM/DMARC results and state the limits of authenticity assessment.

Requirements

Original .eml with full headers, Python 3 and a trusted account of the recipient mail system. DNS tools are optional for current-policy context. No message was supplied here. References: [R19]-[R22].

Procedure

Step 1 - Preserve and extract relevant headers

```
mkdir -p "$HOME/EHF_Exam/Q17"
cd "$HOME/EHF_Exam/Q17"
EMAIL='<EMAIL_FILE>'
sha256sum "$EMAIL" | tee email_before.sha256
cat > inspect_auth.py <<'PY'
import sys
from email import policy
from email.parser import BytesParser

if len(sys.argv) != 2:
    raise SystemExit('Usage: python3 inspect_auth.py message.eml')
with open(sys.argv[1], 'rb') as stream:
    msg = BytesParser(policy=policy.default).parse(stream)
fields = ('From', 'Return-Path', 'Received', 'Received-SPF',
          'Authentication-Results', 'DKIM-Signature')
for field in fields:
    print('\n' + field + ':')
    values = msg.get_all(field, [])
    if not values:
        print('  [not present]')
    for index, value in enumerate(values, 1):
        print(index, ascii(str(value)))
PY
python3 inspect_auth.py "$EMAIL" | tee routing_auth.txt
sha256sum -c email_before.sha256
```

The script preserves the order of repeated headers and unfolds them for inspection; it does not perform cryptographic verification. Keep the original .eml for raw formatting and signed bytes.

Step 2 - Reconstruct the trusted routing portion

Each receiving server normally prepends a Received field, so read bottom-to-top for the claimed chronological route. Record from/by, IPs, protocol and timestamps/timezones. Establish trust from the recipient's known receiving infrastructure downward; lower headers can have been inserted by an untrusted sender. Do not label the bottommost IP as the proven origin. Private IPs may describe internal hops; timestamps can reflect clock skew.

Step 3 - Interpret authentication at the trust boundary

- SPF asks whether the connecting IP is authorized for the envelope MAIL FROM domain (or HELO identity in applicable cases). It does not authenticate the visible From display name or body. pass means authorized under the evaluated policy; fail means not authorized; softfail is a weaker negative policy; neutral/none give no positive authorization. temperror is temporary; permerror indicates a policy/evaluation problem. Forwarding can affect results.
- DKIM checks a signature using the signing domain's DNS public key. In DKIM-Signature, d= is the signing domain, s= is the selector, h= identifies signed header fields, and bh=/b= contain body hash/signature data. A signature field's presence alone is not a pass. A trusted verifier's pass supports integrity of the signed material under that key and canonicalization; it does not identify the human sender or establish safety.
- DMARC evaluates the visible From domain and requires at least one aligned authentication pass: SPF with aligned envelope domain, or DKIM with aligned signing domain. Alignment may be relaxed organizational-domain or strict exact-domain matching. A raw SPF/DKIM pass without alignment can still yield DMARC fail. A published p=none/quarantine/reject expresses requested handling, not a guarantee that every receiver followed it.
- Authentication-Results is useful only when its reporting authserv-id and insertion point belong to a trusted receiving system. A sender can forge header text. Report missing results as unavailable, not failed. A pass can accompany an attacker-controlled lookalike domain or a compromised authorized account.

Step 4 - Optional current DNS context

```
FROM_DOMAIN='<OBSERVED_FROM_DOMAIN>'
ENVELOPE_DOMAIN='<OBSERVED_ENVELOPE_DOMAIN>'
SIGN_DOMAIN='<DKIM_D_DOMAIN>'
SELECTOR='<DKIM_S_SELECTOR>'
dig TXT "$ENVELOPE_DOMAIN" > current_spf_dns.txt
dig TXT "_dmarc.$FROM_DOMAIN" > current_dmarc_dns.txt
dig TXT "$SELECTOR._domainkey.$SIGN_DOMAIN" > current_dkim_dns.txt
```

Use only actual parsed domains/selectors and omit unavailable queries. These current lookups do not reproduce historical authentication: keys/policies may have changed. DMARC policy discovery may fall back to the organizational domain; a missing direct record is not conclusive. Do not manually declare DKIM pass from a DNS key; proper verification requires the original signed message and a verifier.

Expected output - illustrative headers

```
From: Lab <lab@example.org>
Return-Path: <bounce@example.org>
Authentication-Results: mx.example.net;
 spf=pass smtp.mailfrom=example.org;
 dkim=pass header.d=example.org;
 dmarc=pass header.from=example.org
DKIM-Signature: v=1; a=rsa-sha256; d=example.org;
 s=lab; h=from:to:subject:date; bh=[omitted]; b=[omitted]
```

This is a synthetic excerpt with an intentionally incomplete signature, not a verifiable email. If mx.example.net were the trusted receiver and these results were genuine, aligned passes would support domain authentication, not harmlessness.

Interpretation, observation and result

Record each trusted hop, authserv-id, mechanism result, evaluated identity, alignment and limitation. Compare visible From, envelope domain and DKIM d=. Assess links/content separately without opening them. State "reported authentication supported/failed/unavailable at the trusted receiver" and explain the evidence. Do not conclude safe, fraudulent or human-authenticated from one header alone.

Common errors

- Forged Authentication-Results: establish receiver provenance; do not trust every occurrence.
- DKIM failure after forwarding/editing: inspect transformation context; failure alone does not prove malicious intent.
- No authentication fields: obtain full original headers; if still absent, document unavailable results.

Viva questions

- Does SPF authenticate the visible From by itself? No; DMARC alignment connects identities to From.
- Is DKIM-Signature presence proof of a valid signature? No; verification is required.
- Can DMARC pass when SPF fails? Yes, if a valid DKIM signature aligns with From.
- Can authenticated mail be dangerous? Yes, including mail from a compromised or attacker-owned domain.